



22.2 Student Guide: Risk Management and Threat Modeling

Overview

Today's class will introduce cyber risk management and threat modeling.

Class Objectives

By the end of today's class, you'll be able to:

- Identify threat agents, possible attacks, and exploitable vulnerabilities relevant to a given asset.
- Prioritize risks based on likelihood and impact potential.
- Choose and justify controls for a given risk.
- Log in and access your web labs.

01. Welcome and Overview

In the previous class, we covered:

- The roles and responsibilities of the security department
- Applying the security culture framework to build a plan for improving an organization's security culture
- Identifying appropriate security controls for a given resource and situation

Today's class will introduce risk management and threat modeling as methods of identifying, anticipating, budgeting, and planning for risks.

- These tools will allow us to:
 - Enumerate possible risks, threats, and vulnerabilities to a company.
 - Identify the most likely and most serious risks.
 - Evaluate the impact the occurrence of a serious risk may have.
 - Develop strategies for monitoring or mitigating risks.

- These skills will increase your knowledge of technical infrastructure protection, with an emphasis on evaluating what to protect.
-

02. Introduction to Threat Modeling and Risk Management

Risk Management and Threat Modeling

We'll review the basic security elements of vulnerabilities, threats, and risks, and how they apply to the practical business tasks of risk analysis, risk management, and threat modeling.

- Recall the definitions of the terms vulnerability, threat, and risk:
 - A vulnerability is the aspect of a business that can be exploited to compromise a system's CIA (confidentiality, integrity, or availability).
 - A threat is an actor that might exploit a vulnerability. Threats can be intentional (e.g., a malicious hacker steals data), unintentional (e.g., an incompetent sysadmin destroys the network), or due to a natural disaster.
 - A risk is the possibility of losing something valuable. A risk will cost money if it occurs.

Common business practices that organizations employ to understand, manage, and forecast these elements include:

- Risk analysis: Understanding what risks an organization faces, which are most severe, and which are most likely
- Risk management: Using the results of such an analysis to determine how to deploy personnel and spend budget
- Threat modeling: Determining which attacks an organization is most likely to experience, who is most likely to launch them, and what can be done to stop them

These practices directly relate to a business's pursuit of profit:

- Risk analysis is important because it quantifies how much a business will need to spend in the event of a security breach. This allows businesses to plan for such events before they occur.
- Threat modeling is important because risks come with a price, which the business will have to pay if the threat is realized. Threat modeling allows them to prioritize the most expensive risks.

Threat modeling is so essential to running a business that their results are funneled upwards to executives to influence business decisions. We'll continue the lesson focusing on how to perform threat modeling.

Threat Modeling Methodologies

There are multiple approaches to threat modeling. Security professionals often refer to the following industry standard frameworks:

- PASTA (Process for Attack Simulation and Threat Analysis) aims to align consideration of business objectives with technical requirements.
- STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, DoS [Denial of Service], Elevation of Privilege) focuses on identifying what can fail in the system being modeled.
- OWASP (Open Web Application Security Project) focuses on identifying possible threats, prioritizing risks, and planning mitigation strategies. It is mainly applied to the analysis of applications, such as web or desktop apps.

Each methodology is relevant in different situations. A bank might choose PASTA, which gives greater consideration to the business being modeled, while a pen testing firm would probably choose STRIDE or OWASP.

You'll likely encounter more than one of these frameworks during your professional career.

OWASP In-Depth

The OWASP process consists of six steps:

1. Determine assessment scope.
2. Identify threat agents.
3. Identify possible attacks.
4. Identify exploitable vulnerabilities.
5. Rank/prioritize risks.
6. Mitigate risks.

1. **Determine assessment scope:** List the assets under consideration, determine their value, and define objectives for your threat modeling assessment.
 - Determining scope aims to identify which assets an organization wants to assess.
 - Organizations often consider one specific category of risk at a time.

- For example, they might perform a risk analysis to specifically assess the weakness of their network infrastructure and not think about their application security.
 - When an organization focuses on a specific subset of its assets, its adjusting its scope.
- Scope is important because it tells risk analysts what they should focus on and what they can ignore.
 - Scoping begins with asset inventory.
 - Asset inventory is the process of identifying and assigning an asset value (financial worth of an asset) to all of an organization's assets.
 - For assets like a web application, asset value might be measured as revenue and/or profit it generates. A secret recipe might be valued as the amount of revenue generated by that particular dish, plus however much the business gains by being the only one to offer it.
 - Determining scope usually results in a spreadsheet or a written report.
- 2. **Identify threat agents:** A threat agent is a person or group that can actualize a threat, whether they are malicious or not. Analysts also consider "unwitting" sources of threats, such as incompetent employees and natural disasters. However, these unintentional threat agents will not be the focus of today's discussion.
 - Examples include advanced persistent threats (APTs), script kiddies, employees who open phishing emails, and even incompetent users who break configurations on company computers.
- 3. **Identify possible attacks:** Analysts identify which attacks the threat agent would most likely perform.
 - For example: A script kiddie would have different goals than a disgruntled employee. Therefore, they would use different attacks. As such, these are different risks and must be considered separately.

Analysts often consider each threat agent's motivation, skill level, and level of funding when determining which attacks they will attempt.

- For example: Suppose a client's web application is taken offline by a DoS attack. The severity of this risk depends on the threat agent:
- A script kiddie might DoS a server simply to cause trouble.
- An APT, on the other hand, might DoS a server as a smokescreen while they break in elsewhere to steal trade secrets.

4. **Identify exploitable vulnerabilities:** Identify ways for data to enter and exit the system. Analysts evaluate the system for ways malicious attackers can deliver these attacks and which parts of the system are likely to suffer security failures.
 - For example, a web application takes information in from users and sends information back out in response to requests. Consider ways attackers might exploit these points of entry and exit.
 - For example: If your network uses one database to store all data, the entire company will lose access to all data if that machine goes down. An attacker seeking to DoS the company's network can exploit this database to achieve their goal.
5. **Rank/prioritize risks:** Rank which potential attacks are most severe and most likely to occur.
6. **Mitigate risks:** Determine ways to mitigate the most serious risks you identified.

Summary

- Determining assessment scope: Identify all relevant assets and their financial values.
- Identify threat agents: Identify potential attackers who might be interested in these assets and possible unwitting sources of risk.
- Identify potential attacks: Identify attacks that these threat agents are most likely to use.
- Identify exploitable vulnerabilities: Identify areas in the system most vulnerable to these kinds of attacks.

03. Activity: Threat Modeling Steps 1–4

M22.2 - Threat Modeling Steps 1-4

04. Risk Analysis

 **Heads Up:** This section covers some math formulas. Be prepared to allocate a little extra study time to this section.

In this section, we'll focus on risk analysis and explain the process of prioritizing attack possibilities.

Some threat agents and attacks are more likely than others. The goal of these first four steps was to identify all possible threats, including unlikely ones.

- For example: Script kiddies are likely to account for most attacks an organization experiences, simply because they're so numerous.
- For most organizations, organized cybercriminals aren't major threat actors. They're more relevant to financial organizations, branches of government, and military targets.
- Risk analysis is the process of prioritizing these possibilities according to their potential impact and likelihood.

Consider the following scenario to contextualize risk analysis:

- You've identified over 10 potential attacks that GeldCorp should consider. All can be mitigated, but it costs upwards of \$2,500 to implement each fix. The security Department only has \$10,000 budgeted for this project and needs advice on which four fixes would have the greatest security benefit.

We'll proceed by exploring:

- Qualitative vs. quantitative risk analysis
- Likelihood, impact, and loss expectancies
- Risk factor and heat maps

Qualitative vs. Quantitative Risk Analysis

Risk analysis can be conducted qualitatively or quantitatively.

- Qualitative risk analysis is the process of prioritizing risk based on intangible factors.
- Quantitative risk analysis is the process of evaluating each risk based on its measured likelihood and impact.
 - Likelihood is the probability that the event will occur and impact is a measure of how bad it would be.
 - There is an additional metric, called risk factor, which is likelihood multiplied by impact.
 - For example, if a risk has a likelihood of 20 and an impact of 20, its risk factor would be 400.

Not every scenario is easily analyzed qualitatively. Likewise, other scenarios are difficult to quantify. In the next section, we'll differentiate between scenarios that use each risk analysis methodology.

Qualitative Risk Analysis

Qualitative risk analysis is useful because accurately assigning likelihood and impact can be difficult, if not impossible.

- It's impossible to calculate a precise probability that some malicious attacker, somewhere in the world, will attack your servers within the next year.

- It's impossible to precisely determine the fallout of a breach.
 - For example: A company might face the risk of a distributed denial-of-service (DDoS) attack against its core web servers. The cost of this attack depends on how long the attack lasts, which is impossible to determine ahead of time.

Qualitative analysis is typically much faster than quantitative risk analysis, and it might be just as effective for high-level problems.

- For example: A baking company must decide between an inexpensive VPN service that logs traffic on its servers for internal use and a more expensive service that does not keep any logs.
- In this case, a simple qualitative analysis might lead to the conclusion that the less expensive VPN is suitable, since it shouldn't much matter if non-confidential information is being logged.
- A defense organization, on the other hand, would probably choose the more expensive service, as it would prefer to leave no traces.

In either case, a complex evaluation of cost versus benefit is unnecessary.

Quantitative Risk Analysis

Sometimes, intuitive analysis is not enough. The following scenarios require quantitative analysis:

- The security department wants to invest in protecting an organization's infrastructure. To secure money from the finance department, they present a quantitative risk analysis to demonstrate that the cost of not investing is much greater than the budget they're requesting.
- The executive team needs to decide whether to migrate to a new cloud provider as part of negotiations with a potential partner. Since this transition has major financial implications, they won't decide without accurate assessment of potential losses due to downtime, retraining, and risk of data corruption during migration, etc.

Risk analysts use a well-defined methodology to determine the likelihood and potential impact of a given risk.

Asset Value and Exposure Factor

To perform quantitative risk analysis, analysts start by calculating how much it costs if an asset is breached. To calculate this, they first quantify asset value and exposure factor.

- We've previously covered that asset value is how much money the asset is worth in currency.

- In the case of a web application's core application server, the asset value would probably be the amount of revenue or profit generated by that server, not the price of the server itself.
- Analysts also consider how exposure to an attack can result in the partial/temporary or complete/permanent destruction of an asset. For example, a DDoS attack might take down a server for a few hours, but a fire would destroy it for good.
- Analysts quantify this exposure factor by measuring "how much" of an asset will be affected in the event of a breach.
 - Exposure factor is always somewhat subjective. Analysts should start by estimating whether the occurrence of a risk would completely eliminate (1.0), mostly eliminate (0.75), half eliminate (0.5), partially eliminate (0.25), or not affect (0.0) an asset's ability to function.
 - For instance, consider the risk of attackers DDoSing one of an organization's web application servers. If the network has another backup server, the exposure factor might be 0.5, because the attack takes down roughly half of the application's ability to generate profit.
 - For the risk of attackers DDoSing all of an organization's application servers, the exposure factor would be 1.0.

Loss Expectancies

Loss expectancy is a measure of how much money an organization will lose in the event of a breach.

- There are two common methods of measuring loss expectancy:
 - Single loss expectancy (SLE)
 - Annual loss expectancy (ALE)

Analysts use exposure factor and asset value to calculate the SLE.

- SLE is the estimated cost of the occurrence of a risk on a given asset.
 - It is calculated as: $SLE = AV \times EF$, where SLE is single loss expectancy, AV is asset value, and EF is exposure factor.
 - SLE is the estimated cost each time the risk occurs. If it happens twice, the total cost would be twice the SLE.
- ALE is the expected financial loss for an asset due to a risk over one year.
 - It is calculated as: $ALE = ARO \times SLE$, where ALE is annual loss expectancy, ARO is the annual rate of occurrence, and SLE is single loss expectancy.

- Annual rate of occurrence is an estimate of how many times a risk is likely to occur in a given year.
 - For example: We might assume a physical break-in would only happen once a year at most. However, we should guess that phishing attacks could happen as often as monthly.
 - ARO is calculated as follows: $ARO = X / \text{years}$, where ARO is the annual rate of occurrence, X occurrence(s), and years is per number of years.
 - Example 1: 2 attacks every 3 years is $ARO = 2 / 3$. ARO would be 0.67
 - Example 2: 1 attack every 2 years is $ARO = 1 / 2$. ARO would be 0.5

Loss expectancy can be used to categorize a breach's impact as marginal, notable, severe, or catastrophic.

- **Marginal:** The organization has sufficient resources to respond to the breach immediately, without affecting day-to-day operations or revenue.
- **Notable:** The organization has sufficient resources to respond to the breach, but may not be able to do so immediately. It may experience interruptions to operations.
- **Severe:** The organization experiences serious interruptions to operations and does not have sufficient monetary and/or personnel resources to respond to the breach effectively. It may have to defer revenue, delay project timelines, reassign employees, and/or hire consultants to address the issue.
- **Catastrophic:** The organization suffers severe, lasting damage to its reputation and/or infrastructure. The future of the business is threatened by reputational damage, bankruptcy, or being found in contempt of federal regulations, etc.

Different organizations use different categories and thresholds, and these categories will be used throughout today's lesson.

Risk Factor and Heat Maps

These assessments allow us to generate charts that make it easier to understand risks. Today, we'll focus on risk matrices and heat maps.

- A risk matrix is used to compare how many of the risks an organization faces are mild versus how many are severe.
- A heat map is a visual representation of the probability and likelihood of risks to an organization. Heat maps help organizations make strategic decisions to protect the company.

- During a risk assessment, visualization provides a holistic view of risks that affect an organization.
- Heat maps display two relative values:
 - Likelihood/probability is measured from left (low) to top (right).
 - Impact is measured from top (low) to bottom (high).

Demonstration: The Risk Spreadsheet

Risk analysts typically use spreadsheets to automate the calculation of these metrics.

1. Open the spreadsheet and conduct this activity in Google Sheets:
 - [Risk Analysis Template](#)
 - You will be asked to make a copy.
 - Once you have made a copy, review the tabs at the bottom of the sheet: Risk Assessment Heat Map and Dropdown Keys.
2. Click on Dropdown Keys. This tab documents how GeldCorp categorizes probability and impact.
 - Probability is rated based on expected annual rate of occurrence.
 - Impact is rated based on cost. It falls into one of five categories: Insignificant, minor, moderate, major, or severe.
3. Click the Risk Assessment tab and review the columns:
 - REF ID: The numerical ID for the risk
 - DATE RAISED: When the risk was raised
 - RISK DESCRIPTION: A textual description of the risk
 - LIKELIHOOD: Probability that the event will happen (1–5 – Refer to the Dropdown Keys for Description)
 - IMPACT: Monetary impact of the event (1, 2, 4, 8, 16 – Refer to Dropdown Keys for Description)
 - RISK SEVERITY SCORE: Product of likelihood and impact
 - NOTES: Any additional notes for this risk
4. The score of 1–80 is used to map the categories of marginal, noticeable, severe, and catastrophic to numbers.
 - Note that this spreadsheet does not require you to explicitly calculate asset value, exposure factor, SLE, or ALE. You should estimate the ALE directly and use this to determine impact rating.
5. The Heat Map auto-populates as you fill in the Risk Assessment tab.
6. In the DATA TABLE, Severity Score is auto-populated and ranked.
7. An organization will use this completed Heat Map to help prioritize the risks

05. Break

06. Activity: Threat Modeling Step 5: Risk Analysis

 M22.2 - Threat Modeling Step 5

07. Mitigating Risk

Analysts rank risks to determine which threats are worth investing in solutions for. We'll now look at recommending controls for the most critical risks.

Deciding on Security Controls

Determining an appropriate control entails answering the following questions:

- **Required control type:** Should the control be physical, administrative, or technical? Should it be protective, preventive, deterrent, corrective, or detective? Sometimes multiple types of controls might be appropriate.
- **Required strength of control:** How strong does the control need to be? An organization could require everyone to encrypt their disks and refresh their passwords weekly, but it probably doesn't need to.
- **Cost of implementation:** How much does the control cost, relative to how much protection it provides and how much is needed?
- **Time to implementation:** How long will it take to implement this control? Sometimes an imperfect but more immediate fix is better than a fully general solution you can only implement later.

Additionally, consider what resources your client has available when deciding on controls. Some organizations can afford "proper" solutions, while others might only be able to implement something "good enough."

Mitigation Example

Read the following scenario as an example of a risk mitigation method:

Unset

LifeNotes is a new medical records company that allows doctors from different hospitals to share medical records with each other. When transferring patients, they can use the LifeNotes app to send the patient's medical history, lab results, and medication schedules, etc. LifeNotes also ensures that doctors can only see records for their own patients.

The app functions like "Google for medical records." To use it, doctors log in with a password, search for a patient by name, select the correct patient, and then view the patient's records.

However, a client recently reported that they were able to load records for patients they were not assigned to. They noticed this because they accidentally clicked on the wrong search result, but were still able to load that patient's medical details.

This violates regulatory standards for protecting patient medical information, and it must be resolved immediately.

This is a security issue because it violates client-data confidentiality.

Some example controls for this problem:

- Required control type
 - Since this problem must be fixed immediately, LifeNotes must implement a corrective control. It should also implement protective controls to prevent the issue from reoccurring.
 - It can accomplish this with either administrative or technical controls.
- Required control strength

- The corrective control must completely resolve the issue because the bug means LifeNotes is in violation of the law.
 - The protective control(s) must completely prevent this issue from reoccurring, for the same reason.
- Controls
 - LifeNotes can implement the following example controls:
 - As a corrective control, it can redeploy the older version of the application, which did not have this issue.
 - As an administrative preventive control, it can require doctors to transfer records to the target hospital, and then have the hospital give those records to the specific doctor who needs them.
 - As a technical preventive control, it can require doctors to provide a password to log in and their employee ID to load a specific patient's records. This is called two-factor authentication.
- Cost of implementation
 - Returning to an older version of the application is low cost, as it simply requires redeploying an older version of the application.
 - Changing the way doctors and hospitals communicate data with one another is high cost. This requires clients to change their processes and LifeNotes to change how its application works.
 - Implementing two-factor authentication is medium cost. It requires the engineering team to implement a new feature and doctors to learn a new workflow. However, this is an acceptable amount of work for both doctors and developers, as this would entirely control the issue.
- Time to implementation
 - Rolling back to an older version should take less than one day.
 - The administrative control would take months to implement.
 - Implementing two-factor authentication would likely take about a quarter (three months). This will vary by company.

08. Activity: Threat Modeling Step 6 – Mitigating Risk

M22.2 - Threat Modeling Step 6